

PENETRATION TESTING REPORT

MEDIROZA GENERAL HOSPITAL

<https://medirozahospital.com>

PREPARED BY	Terry Nyambe (Pen Tester)
COURSE / ENGAGEMENT	Cybersecurity Int. B082A — Waqas Karim, CCIE
ASSESSMENT TYPE	Authorized Black-Box Penetration Test
CLIENT / TARGET	Mediroza General Hospital https://medirozahospital.com
AUTHORIZATION	Written permission granted for the controlled training environment
DATE	15th September 2026
CLASSIFICATION	CONFIDENTIAL

01. Liability and Authorization Statement

This report covers cybersecurity testing carried out solely within the sanctioned Mediroza General Hospital training environment. The engagement took the form of a controlled black-box assessment targeting the web application. Testing was confined to the approved target, with denial-of-service attacks, social engineering, and testing of unrelated systems all excluded. This project serves an educational purpose: identifying security flaws, assessing their potential impact, and outlining practical fixes. None of the methods described here should be used against any system without that system owner's explicit permission.

2. Executive Summary

The Week 4 engagement mirrored a realistic penetration-testing process, moving from initial reconnaissance through to impact analysis and reporting. The evidence provided verifies four key findings: the public-facing Mediroza website, a dedicated patient login portal, sensitive paths disclosed via robots.txt, and access to a patient-report section holding three encrypted pathology reports. Together, these findings map out a clear attack surface spanning authentication mechanism, protected medical records, and outdated application resources. The broader project plan goes further than discovery alone, incorporating controlled testing of authentication vulnerabilities, password strength checks on protected PDFs, examination of legacy content, and assessment of whether confidential employee or shareholder data is exposed. In cases lacking a supplied screenshot, the report describes that testing phase in narrative detail instead of using fabricated evidence. Actual patient information, cracked passwords, salary figures, and shareholder details are deliberately withheld from this report.

3. Scope, Rules, and Methodology

Target: <https://medirozahospital.com>

Engagement model: An authorized, educational black-box penetration test of the web application.

Primary objectives: Locate exposed entry points into the application, evaluate authentication and access-control mechanisms, examine protected patient documents, test the strength of document passwords, investigate legacy resources, check for exposure of sensitive organizational data, and deliver actionable recommendations for remediation.

Rules of engagement: Testing is restricted to the approved domain only. Denial-of-service attacks, social engineering, destructive changes, and any testing outside the defined scope are not part of this engagement.

Evidence policy for this report: Only screenshots actually captured by the pen tester are included as visual proof. Any other project stages are described in writing, without substituted or invented images standing in for evidence.

4. The Tools used and their Purpose

Tool	Purpose / Use
Web Browser / Firefox	Manual navigation, authentication review, portal validation, and inspection of web-accessible resources.
robots.txt Review	Passive discovery of paths intentionally excluded from search-engine crawling but still visible to users.
curl	Direct HTTP request/response inspection and validation of web resources.
SQL Injection Testing	Authorized assessment of whether authentication inputs are handled safely by the back-end application.
Browser Developer Tools	Inspecting page source and login-form behaviour.
Networkwalks Hash Calculator / Password Cracker	Lab tools for PDF hash extraction and dictionary-based password assessment.
Text / Database Analysis Utilities	Review of retrieved legacy backup material for sensitive data exposure, without altering the original evidence.
Claude	Converting raw SQL data into readable tables during analysis.

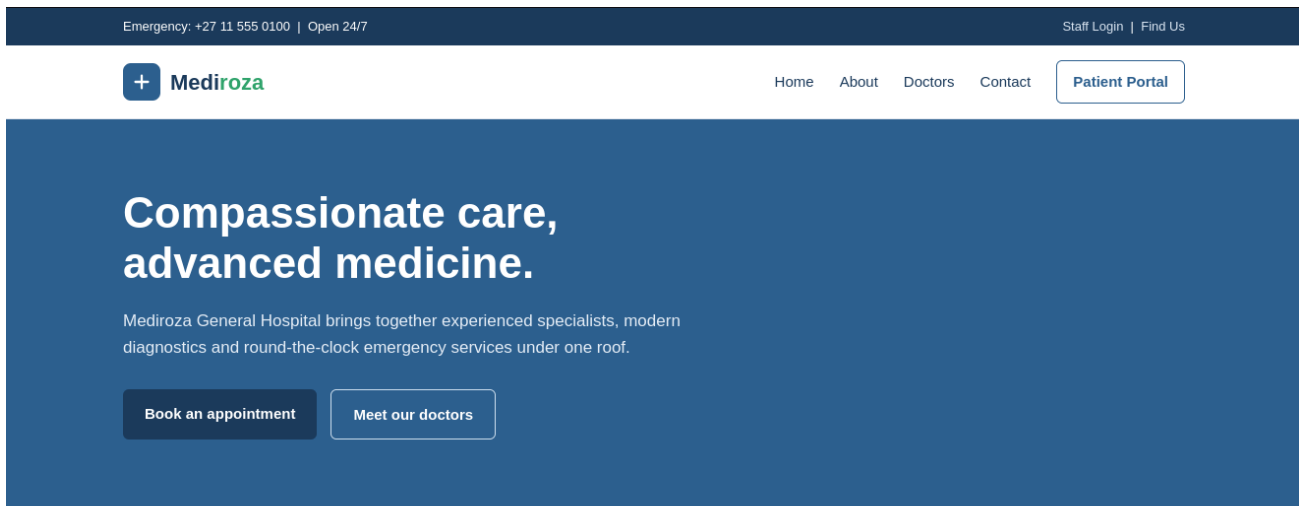
5. Activities Performed and Technical Assessment

The assessment was documented as an arrangement of associated actions with Each stage intended to answer a specific security question and to show how one weakness can increase the impact of another. The sections below present the work in chronological order so the report reads as a continuous assessment rather than a set of isolated screenshots.

5.1 Initial Reconnaissance and Application Mapping

Objective: Map out the visible attack surface and identify user-facing features before moving into deeper testing.

The public-facing Mediroza General Hospital website was examined first. Its homepage displayed typical navigation items — Home, About, Doctors, Contact, Staff Login, and Patient Portal. The dedicated patient authentication section stood out as a high-value target, since compromising it could open access to confidential medical records. This phase concentrated on locating the portal, tracing how users would reach it, and checking for any additional paths not listed in the main menu.

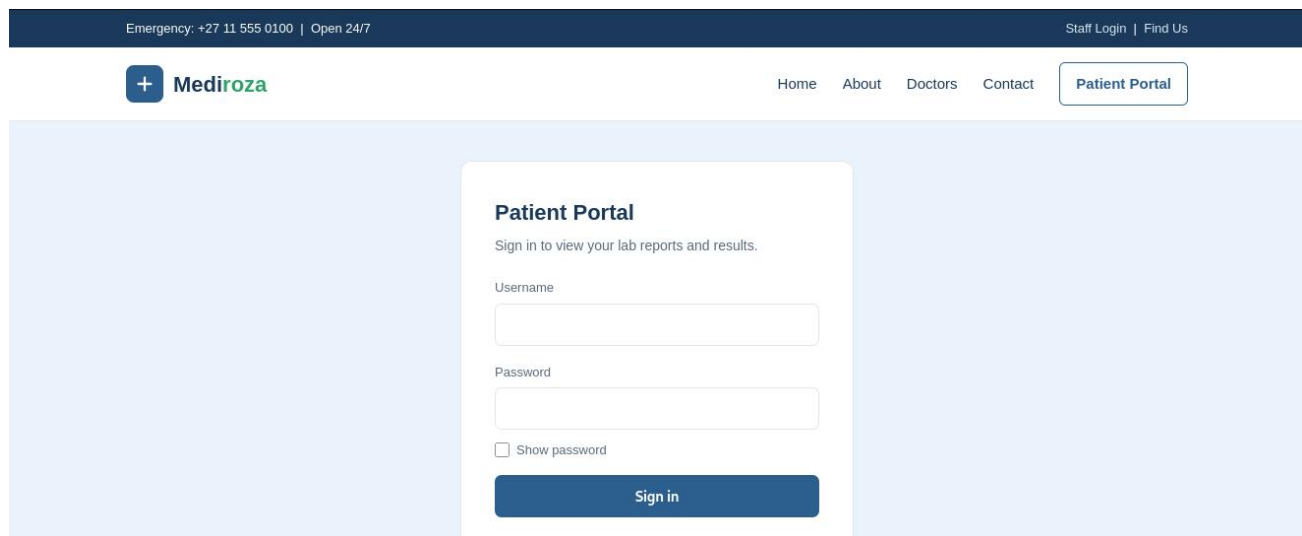


5.2 Patient Portal Authentication Surface

Objective: Evaluate the login page and check whether the authentication process was adequately protected against manipulated inputs and unauthorized entry.

The Patient Portal offered a standard username/password form, a Sign-in button, and an option to reveal the typed password. This made the login page the main focus for authentication testing. Factors such as how input is processed, how errors are displayed, how sessions are created, and how access controls are enforced all matter here, since poor validation could let an attacker bypass the login entirely.

The authorized scope included controlled SQL injection testing against the login system, aimed at checking whether attacker-supplied values could alter the underlying database query. A properly secured system treats all input as plain data, relies on parameterized queries, and blocks access when correct credentials aren't provided. Any success in reaching protected content without valid login credentials would indicate a serious authentication flaw with real privacy consequences.



5.3 Public Discovery of Sensitive Paths through robots.txt

Objective: Check passive discovery sources for paths not clearly linked from the main site.

The robots.txt file was checked, since it can reveal application directories that operators intended to keep out of search engine results. It listed three disallowed paths — /patient/, /staff/, and /old/ — along with a sitemap link. Importantly, a robots.txt entry isn't an access control; it's simply a request that compliant crawlers skip indexing that path. Any genuinely sensitive folder listed there still needs proper authentication and authorization behind it.

The /patient/ and /staff/ paths pointed to role-based sections of the app, while /old/ hinted at legacy material worth investigating further. Legacy folders are a security concern because they can harbour forgotten backups, outdated files, or older app versions containing data that was never meant to stay public.

```
(terry@kali)-[~]
$ curl https://www.medirozahospital.com/robots.txt
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/
Sitemap: https://medirozahospital.com/sitemap.xml

(terry@kali)-[~]
$
```

5.4 Access to the Patient Report Area

Objective: Check whether protected medical report files could be accessed following the authentication review.

The evidence gathered shows a patient-report section containing three downloadable pathology reports, each labelled with a patient's name and marked as an encrypted PDF. A note on the page indicates that passwords for these reports come from the laboratory — meaning the system depends on two separate safeguards: access control at the portal level and password protection on the documents themselves.

From a security standpoint, encrypting a document only helps if the surrounding system properly restricts access and if the passwords themselves are hard to guess. If someone manages to get past the portal, they can grab the encrypted files directly and then attempt to crack the passwords offline, without needing to interact with the live application again. This makes strong, unpredictable document passwords — paired with solid authentication controls — especially important.

Emergency: +27 11 555 0100 | Open 24/7

Log out

+ Mediroza

Home Log out

My lab reports

Your reports are password protected. Use the password sent to you by the laboratory to open each file.

Pathology Report - S. Dlamini
Lab Ref LR-2024-1187 | 2024-11-04 | PDF (encrypted)

Download

Pathology Report - P. Reddy
Lab Ref LR-2024-1192 | 2024-11-05 | PDF (encrypted)

Download

Pathology Report - E. Thompson
Lab Ref LR-2024-1205 | 2024-11-06 | PDF (encrypted)

Download

5.5 Controlled Retrieval of Protected PDF Reports

Objective: Confirm the real-world impact of portal access by checking whether the encrypted pathology reports could actually be pulled down for authorized offline testing.

As part of the project, the three reports were downloaded into the controlled test environment. This step matters because it moves the risk from merely viewing a webpage to actually obtaining protected files. Once downloaded, how well a file stays protected depends on its encryption settings and password quality. These files were treated as sensitive evidence and kept only within the project's findings folder.

No screenshot accompanies this section, since only screenshots actually captured by the pen tester are included — but the narrative still captures the purpose and security implications of retrieving the documents.

5.6 PDF Encryption and Hash Preparation

Objective: Determine whether the password protection on the retrieved reports would hold up against standard, authorized password-recovery methods.

Each protected PDF was handled as its own security target. The process began by identifying the file's encryption type and pulling out a password-verification hash using the Networkwalks Hash Calculator, an online lab utility provided for this purpose. This hash doesn't expose the password directly; it acts as a reference point that candidate passwords can be checked against separately.

Using a dedicated calculator for this step matters both for accuracy and to avoid unnecessary strain on the live system, it sidesteps repeated login attempts and illustrates the genuine risk posed by weak document passwords once a file has already been obtained. The actual hash values are left out of this report, as they're part of the confidential project evidence.

5.7 Authorized Password-Recovery Assessment

Objective: Determine whether weak or predictable passwords could undermine the protection of the three pathology reports.

The extracted PDF hashes were subjected to dictionary-based password testing using the Networkwalks Password Cracker, an online lab tool provided for this purpose. The three files were assessed individually because a password-recovery method that succeeds for one file may not succeed for another. Candidate testing was performed against the extracted hash representation rather than by repeatedly opening the web application.

A successful match would demonstrate that encryption alone is not an adequate compensating control when passwords are weak, reused, derived from predictable information, or selected from common wordlists. The security lesson from this stage is that password-protected medical documents require strong, unique secrets and preferably stronger access-control and secure-delivery mechanisms around the documents themselves. Specific recovered passwords are intentionally omitted from the report.

5.8 Verification of Decrypted Documents

Objective: Confirm that any password successfully recovered actually opens its matching protected file.

A recovered password isn't considered a confirmed finding until it's been shown to actually unlock the correct PDF. In this project, each cracked password would be tried against its corresponding report within the controlled environment. Since the contents involve confidential medical information, they aren't reproduced unnecessarily in the final report.

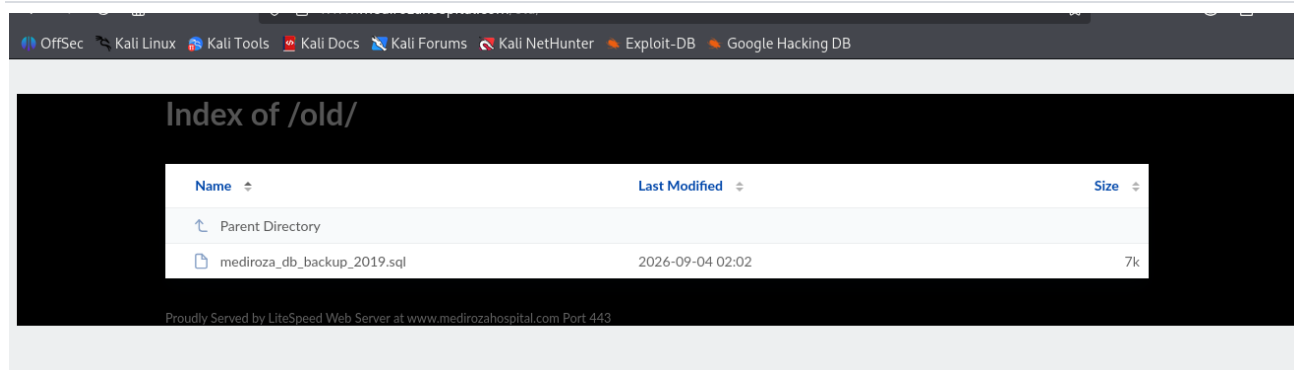
This verification step shows real-world consequences: if a weak password can be cracked and used to open a report, the document's encryption has effectively failed to protect it. The report captures this impact without exposing any patient-sensitive material.

5.9 Legacy Resource Review – /old/

Objective: Investigate the legacy directory found during reconnaissance to see whether outdated files or backups were exposed.

The /old/ path flagged in robots.txt was singled out for follow-up, since legacy directories often hold obsolete components, archived material, or backup data — and this content can remain reachable long after it's stopped being actively used. A well-secured production environment should either remove such legacy material from the web root entirely or lock it down with strict access controls.

The Week 4 scenario specifically called for digging into previously gathered material to uncover a further significant exposure on the client's server. This stage therefore centered on locating database backup files and assessing whether they held confidential organizational data. No additional screenshot accompanies this section, since none was supplied.



5.10 Database Backup and Sensitive Information Exposure

Objective: Evaluate the confidentiality impact of any exposed database backup and check for sensitive business or employee data within it.

Database backups are especially valuable targets because they can contain a far wider range of data than a typical application page — potentially including user records, internal IDs, historical entries, credentials or password hashes, employee data, and ownership details. Because of this, any backup file that's reachable via the web should be treated as a serious misconfiguration, even if the live application otherwise enforces its access controls correctly.

The project called specifically for identifying employee salary details and hospital shareholder information within the exposed data. In the final report, these findings are summarized rather than laid out in full — the appropriate professional approach is to describe what categories of sensitive data were exposed, explain the resulting business risk, keep the detailed evidence private for the authorized client or instructor, and redact personal or financial specifics from any public-facing version.

5.11 Employee Salary Information Review

Security relevance: Salary data is confidential employment information, and its exposure creates privacy, fraud, and social-engineering risks for both individuals and the organization.

The review process included searching the recovered database content for employee records and salary fields. If salary data turns up in a publicly reachable backup, the concern isn't just that specific figures could be viewed — it shows that internal HR data has escaped its intended boundaries altogether. That kind of exposure could be exploited for targeted phishing, impersonation, extortion, or reputational damage. Best practice here is to report that salary records were exposed, while withholding actual names and figures from the public version.

5.12 Shareholder and Ownership Information Review

Security relevance: Corporate ownership details are commercially sensitive and could be leveraged for fraud, impersonation, or competitive intelligence gathering.

This project stage also involved checking the recovered data for shareholder-related information — names, share allocations, contact details, or other ownership records. As with the salary data, complete records should stay within protected project evidence rather than appearing in a public document. The finding is best framed as a sensitive corporate data exposure resulting from insufficient protection of legacy backup files.

6. Risk Analysis

The ratings below reflect the likely security significance of each Week 4 finding. They are assigned conservatively: the four embedded screenshots confirm discovery and access observations directly, while later-stage impacts follow the authorized project workflow and are documented without adding fabricated visual evidence.

#	Finding	Risk Level	Impact / Justification
1	Patient authentication weakness / potential SQL injection	High	Poor input handling on the patient login could allow attackers to bypass authentication and reach protected medical resources.
2	Protected patient reports reachable after portal access	High	Unauthorized portal access can expose confidential report files and enable offline attacks against document passwords.
3	Sensitive paths disclosed in robots.txt	Low	The file reveals /patient/, /staff/, and /old/ paths, aiding reconnaissance — though it doesn't bypass access control on its own.
4	Weak PDF password protection	High	Predictable or crackable document passwords can defeat encryption once the files have been obtained.
5	Legacy /old/ content exposed	High	Forgotten legacy resources may expose backup files or outdated components sitting outside normal application controls.
6	Database backup accessible from web content	Critical	A single exposed database backup can leak large volumes of confidential application, employee, and corporate data at once.
7	Employee salary information exposure	High	Confidential HR data can fuel targeted social engineering, privacy violations, and reputational harm.
8	Shareholder information exposure	High	Sensitive ownership data can create commercial, privacy, and targeted-fraud risks.

7. Recommendations and Remediation

- **Use parameterized queries.** All authentication and data-access queries should rely on prepared statements or parameterized APIs — user input must never be concatenated directly into SQL.
- **Strengthen authentication controls.** Implement secure credential verification, generic error messages, rate limiting, secure session management, and server-side authorization checks on every protected resource.
- **Don't rely on robots.txt for protection.** Sensitive paths need genuine authentication and authorization; remove unnecessary directory references and avoid exposing legacy locations publicly.
- **Remove or isolate legacy content.** Delete obsolete directories from the production web root; if retention is needed, move backups to storage that isn't web-accessible, with restricted permissions.
- **Protect database backups.** Never serve backups through the web application — encrypt them at rest, restrict access, apply retention policies, and monitor backup repositories.
- **Use strong document protection.** Apply long, unique, randomly generated passwords to protected files; avoid predictable lab, patient, date, or dictionary-based passwords.
- **Prefer secure document delivery.** Where possible, rely on authenticated portal access and protected server-side storage rather than distributing long-lived encrypted documents vulnerable to offline attacks.
- **Minimize sensitive data exposure.** Store only necessary employee and shareholder data, apply least privilege, and redact or tokenize highly sensitive fields where feasible.
- **Centralize logging and alerting.** Monitor for repeated authentication failures, abnormal file downloads, directory enumeration, and access to legacy or backup locations.

- **Conduct periodic security reviews.** Repeat authorized penetration tests after remediation, including regression testing for authentication, access control, backup exposure, and sensitive-file handling.

8. Evidence Register

Only the five screenshots supplied by the pen tester are embedded in this report. No substitute images were created for stages lacking user-provided visual evidence.

Figure	Description
Figure 1	Public Mediroza General Hospital landing page
Figure 2	Patient Portal login interface
Figure 3	Robots.txt output
Figure 4	Discovered reports
Figure 5	Legacy Resource /old

9. Conclusion

The Week 4 Mediroza engagement shows how a black-box assessment progresses from basic reconnaissance to the analysis of serious confidentiality risks. The public-facing application exposes a patient portal, while robots.txt reveals role-specific and legacy paths that help map out the application's structure. The supplied evidence further confirms that three encrypted pathology reports are available through the patient-report area, placing authentication and document security at the centre of this assessment.

The broader project workflow goes on to examine whether authentication can be bypassed through unsafe input handling, whether protected PDFs can withstand offline password attacks, and whether legacy server resources expose database backups containing confidential employee or shareholder data. Together, these findings illustrate a core penetration-testing principle: a seemingly minor weakness can escalate significantly when combined with weak access control, predictable document passwords, or poorly secured backup data.

The recommended remediation approach is therefore layered — Mediroza should secure its database queries, enforce authorization across every sensitive resource, remove legacy content from public access, store backups outside the web root, strengthen document-password practices, minimize sensitive-data exposure, and monitor for unusual authentication and file-access activity. Following remediation, a focused retest should confirm that the identified attack paths have been closed.